

Actividad 1

Nombre: Mayra Alejandra López Suárez

Fecha: 03/09/2026

Proyecto: Evaluación de Seguridad E-commerce — Aurora Market

1. OBJETIVO DEL PENTEST

- **Identificación de vulnerabilidades de aislamiento de datos y control de acceso:** Evaluar la presencia de fallas en la aplicación web para verificar la brecha reportada por el cliente sobre exposición de datos entre sesiones de usuarios.
- **Evaluación del perfil de seguridad en funcionalidades de E-Commerce:** Probar la solidez del flujo transaccional (registro, autenticación, carrito de compras, gestión de pedidos y módulo administrativo de empleados) ante ataques de manipulación de lógica de negocio o elevación de privilegios.
- **Generación de informe de riesgos y remediación:** Proporcionar un análisis de impacto de los hallazgos con recomendaciones técnicas específicas para fortalecer el código base y mitigar vectores de explotación sin afectar las operaciones reales del negocio.

2. ALCANCE

- **Sí se evaluará (Dentro del alcance):**
 - Aplicación web principal de Aurora Market (portal de clientes: autenticación, catálogo, carrito, proceso de checkout y panel de pedidos).
 - Panel administrativo/portal de empleados (módulos de gestión de productos, usuarios y pedidos).
 - Mecanismos de gestión de sesiones, cookies, tokens y control de acceso en las llamadas API/endpoints asociadas a la plataforma.
- **Fuera del alcance:**
 - Redes sociales oficiales de la empresa.
 - Cuentas de correo electrónico corporativas o de empleados.
 - Equipos personales (endpoints/laptops) de colaboradores o administradores.
 - Proveedores externos o servicios de infraestructura de terceros no especificados en el objetivo.
 - Pruebas de denegación de servicio (DoS/DDoS) o técnicas destructivas sobre la infraestructura.

3. AUTORIZACIÓN Y CONDICIONES

- **Permisos requeridos:**
 - Documento firmado de Carta de Autorización formal que otorgue permiso explícito al equipo de Ethical Hacking **ALSOFT Consulting**.
 - Entrega de credenciales de prueba con diferentes niveles de privilegio (cuentas de usuario final/cliente y cuentas de empleado de prueba).
- **Condiciones acordadas:**

- **Ventana de ejecución:** Las pruebas técnicas activas se ejecutarán exclusivamente en **horarios de menor actividad** (ventanas nocturnas o de bajo tráfico) para minimizar el impacto operacional.
- **Prohibición de denegación de servicio:** No se realizarán pruebas que degraden o interrumpan la disponibilidad de la plataforma en producción.
- **Protección de datos reales:** Prohibida la modificación, eliminación o extracción masiva de información real de clientes.

4. TIPO DE PENTEST

- **Caja Gris :**
 - *Justificación:* Aurora Market proporcionó una descripción general del funcionamiento (módulos web, roles de usuarios y empleados, y flujo de datos) sin entregar código fuente ni arquitectura interna detallada. Este enfoque optimiza el tiempo de evaluación al simular tanto a un atacante externo con conocimiento limitado de la plataforma como a un usuario/empleo malicioso que intenta escalar privilegios o acceder a datos de terceros.

5. PLANIFICACIÓN

- **Objetivos:** Definir los 3 pilares de evaluación técnica de la plataforma web.
- **Alcance:** Delimitar únicamente la aplicación web y excluir infraestructura de terceros o equipos personales.
- **Permisos y Condiciones:** Validar el acuerdo de confidencialidad (NDA), la carta de autorización formal y las ventanas de mantenimiento.
- **Metodología a utilizar:** Aplicar el estándar **OWASP**
- **Recopilación de información previa:** Fase de reconocimiento pasivo/activo sobre dominios, subdominios y endpoints públicos.
- **Recursos necesarios:** Burp Suite Professional, OWASP ZAP, navegadores aislados, scripts personalizados de pruebas API y cuentas de laboratorio.
- **Programación del Pentest:** Cronograma estructurado dividiendo las fases de reconocimiento, análisis, explotación controlada, post-explotación e informe.

6. FASES DEL PENTEST

1. **Reconocimiento:** Mapeo de la aplicación web, identificación de rutas, parámetros de URLs, formularios de entrada, endpoints de API y análisis del manejo de cookies/tokens de sesión.
2. **Análisis de Vulnerabilidades:** Escaneo enfocado y análisis manual para identificar fallas de control de acceso, inyecciones (SQLi, XSS), parámetros manipulables y configuraciones inseguras.
3. **Explotación:** Validación técnica de los hallazgos mediante la ejecución de exploits controlados que demuestren el impacto (por ejemplo, acceder al pedido de otro usuario mediante la modificación manual de identificadores de sesión/parámetros) sin alterar la base de datos real.
4. **Post-Explotación:** Evaluación del alcance del hallazgo: determinar si desde un acceso no autorizado de usuario cliente es posible llegar al panel administrativo o extraer datos sensibles adicionalmente.

5. **Informe:** Elaboración del entregable técnico y ejecutivo detallando las vulnerabilidades encontradas, su nivel de riesgo (según CVSS), evidencia PoC y sugerencias de remediación para el equipo de desarrollo.

7. INVESTIGACIÓN DE METODOLOGÍA

- **Metodología seleccionada: OWASP**
- **Justificación de elección para este proyecto:**

OWASP WSTG es el estándar internacional específico para la evaluación de seguridad en aplicaciones web y comercio electrónico. Es la metodología idónea para este caso porque incluye listas de verificación (*checklists*) detalladas para evaluar controles de identidad, gestión de sesiones y controles de acceso a nivel de parámetro (clave para investigar el incidente reportado de fuga de datos entre cuentas). Permite garantizar una cobertura completa de las vulnerabilidades más comunes en aplicaciones web modernas mediante un proceso repetible y profesional.